

Detectando ataques Web

Investigação

O BankX, uma pequena plataforma de banco online, sofreu uma violação de segurança. Cibercriminosos invadiram o sistema e vazaram dados confidenciais de clientes em um fórum da darkweb. A administração acredita que a intrusão começou pelo site público da empresa, e cabe a mim descobrir exatamente como isso aconteceu. O arquivo que me foi enviado é: access.log.

Minha missão é analisar os logs e refazer os passos do invasor para revelar como a violação ocorreu.

1 - Qual é o User-Agent do invasor ao realizar o fuzzing de diretório?

Resposta: FFUF v2.1.0

```
access.log x
192.168.1.10 - - [20/Aug/2025:07:37:38 +0000] "GET /login.php HTTP/1.1" 200 241 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:38 +0000] "GET /social HTTP/1.1" 404 273 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:38 +0000] "GET /images HTTP/1.1" 404 273 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:38 +0000] "GET /manage HTTP/1.1" 404 273 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:38 +0000] "GET /corporate HTTP/1.1" 404 273 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:38 +0000] "GET /company HTTP/1.1" 404 273 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:38 +0000] "GET /files HTTP/1.1" 404 273 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:38 +0000] "GET /home HTTP/1.1" 200 265 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:38 +0000] "GET /catalog HTTP/1.1" 200 335 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:38 +0000] "GET /products HTTP/1.1" 200 261 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:39 +0000] "GET /features HTTP/1.1" 404 273 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:40 +0000] "GET /jobs HTTP/1.1" 404 273 "FFUF v2.1.0"
192.168.1.10 - - [20/Aug/2025:07:37:40 +0000] "GET /adminpanel HTTP/1.1" 404 273 "FFUF v2.1.0"
```

2 - Qual é o nome da página na qual o invasor realiza um ataque de força bruta?

Resposta: /login.php

```
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "GET /login.php HTTP/1.0" 200 403 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "GET /login.php HTTP/1.0" 200 403 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "GET /login.php HTTP/1.0" 200 403 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "GET /login.php HTTP/1.0" 200 403 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "GET /login.php HTTP/1.0" 200 403 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "GET /login.php HTTP/1.0" 200 403 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "GET /login.php HTTP/1.0" 200 403 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "GET /login.php HTTP/1.0" 200 403 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "GET /login.php HTTP/1.0" 200 403 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "GET /login.php HTTP/1.0" 200 403 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 302 - "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
192.168.1.10 - - [20/Aug/2025:07:38:09 +0000] "POST /login.php HTTP/1.0" 200 457 "Mozilla/5.0 (Hydra)"
```

3 - Qual é o payload SQLi completo e decodificado que o invasor usa no formulário /changeusername.php?

Resposta: %' OR '1'='1

```
changeuser|name.php?q=%25%27+OR+%271%27%3D%271 HTTP/1.1" 200 289
```



Autor: Paulo Cesar
Formado em Segurança da informação
[linkedin.com/in/paulo-cesar-security](https://www.linkedin.com/in/paulo-cesar-security)